SRI LANKA INSTITUTE OF INFORMATION TECHNOLOGY

FACULTY OF COMPUTING.

WEB SECURITY- IE2062

IT22121592 – HERATH H.M.C.H.K

Y2S2

Contents

Subdomain Enumeration: 3
Vulnerability title. 4
Vulnerability description. 4
Affected components. 5
Impact assessment. 7
Steps to reproduce. 9
Proposed mitigation or fix. 10

The subdomain chat.bigcommerce.com

Subdomain Enumeration:

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ dig chat.bigcommerce.com @8.8.8.8
;; communications error to 8.8.8.8#53: timed out

; <<>> DiG 9.19.21-1-Debian <<>> chat.bigcommerce.com @8.8.8.8
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 45959
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;chat.bigcommerce.com.          IN      A

;; ANSWER SECTION:
chat.bigcommerce.com.   900     IN      CNAME   d1fst8v83vh1i2.cloudfront.net.
d1fst8v83vh1i2.cloudfront.net. 60 IN    A       13.33.30.39
d1fst8v83vh1i2.cloudfront.net. 60 IN    A       13.33.30.101
d1fst8v83vh1i2.cloudfront.net. 60 IN    A       13.33.30.9
d1fst8v83vh1i2.cloudfront.net. 60 IN    A       13.33.30.118

;; Query time: 228 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Fri Oct 18 08:49:13 +0530 2024
;; MSG SIZE  rcvd: 156
```

Vulnerability title.

Security misconfiguration.

1- Missing security headers.
2- Line related to strict- transport security.
3- X-amz-cf-poop and x-amz-cf-id headers.

Vulnerability description.

Security misconfiguration happens when an application or server isn't set up leading to vulnerabilities present, at various levels of an application stack such as the operating system and different servers like web servers or database servers along with frameworks, in use.

Commonly Used Logins and Passwords: Utilizing usernames and passwords that are pre-set, within applications or devices; these are well-known and vulnerable, to exploitation.

Unneeded Functions Activated: Keeping services or functions enabled can create vulnerabilities, for potential attacks. For instance, an app could have a debugging tool in a live setting.

Issues with HTTP Headers: When there are missing or incorrectly set up HTTP security headers like Content Security Policy (CSP) X. Content. Type. Options or X. Frame. Options that could potentially leave the application vulnerable, to cross. Site scripting (XSS). Click jacking attacks.

Granting users or applications permissions can lead to them accessing sensitive information or system features that are not essential, for their designated tasks.

Error Alerts: Showing, in-depth error alerts to users at the end might expose details regarding the structure of the application or database, to hackers and assist them in devis-ing more potent attacks.

Neglecting to install updates or patches, for software can expose known vulnerabilities that attackers can exploit.

Affected components.

Security misconfigurations can have a reaching impact, across parts of an application or infrastructure affecting several key components, in particular:

1. Web servers:

Misconfigured web servers have the potential to reveal information by displaying error messages or permitting directory listings that could be exploited by attackers to access files and resources.

2. Application servers:

If application servers have default configurations or unnecessary services running on them without setup, in frameworks and middleware settings can make them vulnerable, to exploitation.

3. Databases:

Improperly set up databases may inadvertently reveal information. Permit unauthorized entry due, to inadequate authentication systems or default administrative accounts which could result in data breaches.

4. Network devices:

Network equipment like routers and switches that have default settings, could potentially lead to access or interception of traffic which can put network security at risk.

5. APIs:

Inadequate settings for APIs can result in data breaches or unauthorized access to API endpoints due, to lacking authentication and authorization controls.

6. Cloud services:

Misconfigurations in cloud services like storage buckets or incorrect network security configurations may result in data exposure and unauthorized entry, to sensitive information.

7. Content management systems (CMS):

CMS platforms that are set up with their default settings or have not been updated with the patches, for plugins/themes may be vulnerable to security breaches, like SQL injection or cross-site scripting (XSS).

8. Operation systems:

Unprotected operating systems that have not been customized or updated can serve as a vulnerability that attackers may exploit to gain access.

9. IAM:

Issues with Identity and Access Management (IAM) can arise from configurations of IAM settings leading to permissions or incorrect user roles that may grant unauthorized access, to important resources.

10. Development and testing environments:

Security misconfigurations, in development or testing environments may expose vulnerabilities that could be exploited before they are transferred to the production stage.

Impact assessment.

Performing an evaluation of the effects of security misconfigurations aids companies, in grasping the outcomes and deciding which areas to focus their efforts, on for fixes. Here are crucial elements to take into account during such an evaluation:

Potential Dangers of Data Breaches:

- Sensitive information such, as details (like names and addresses) financial records or intellectual property could be, at risk of exposure if databases or APIs are not configured correctly.
- Unauthorized entry into a system, could cause changes, to data integrity. Lead to the dissemination of information that may impact business functions and decision-making processes adversely.

Operational Impact:

- Mishandling configurations can result in downtime which may cause service disruptions and impact user's ability to access applications.
- Issues with performance can arise from servers or network devices being misconfigured which could result in response times and a poorer user experience.

Reputation damage:

- A known data breach or security incident can harm a company's image by eroding trust, among customers and potentially causing a drop, in revenue.

- Media attention focused on a security breach can result in increased scrutiny, from bodies and interested parties which can exacerbate harm.

Legal and Regulatory Ramifications:

- Non-Compliance Issues: Not safeguard-ing information could lead to breaches of rules and laws (such, as GDPR or HIPAA) which may incur fines and legal consequences.
- Legal Troubles Ahead: If customers or partners are impacted by data breaches they might take steps leading to legal battles.

The financial consequences:

- Dealing with security incidents can be quite costly, due, to the expenses involved in investigating the issue and implementing measures to contain and recover from it.
- A decline in income may result from service interruptions or a breach of customer confidence leading to reduced sales and lasting financial setbacks.

The influence on trust and customer connections:

- Customer Loss: Some customers may decide to switch their services to providers because they're worried, about the security and safeguarding of their data.
- Building relationships requires trust that is not easily regained when broken – restoring customer confidence may take years to mend the bond.

Potential Areas for Exploitation:

- Expanding Vulnerabilities; Errors, in configuration can offer attackers entry points, for exploitation raising the chances of successful attacks occurring.
- Automated assaults are commonly carried out by attackers using software to search for recognized misconfigurations in order to exploit vulnerabilities promptly.

Steps to reproduce.

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ dig chat.bigcommerce.com @8.8.8.8
;; communications error to 8.8.8.8#53: timed out

; <<>> DiG 9.19.21-1-Debian <<>> chat.bigcommerce.com @8.8.8.8
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 45959
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;chat.bigcommerce.com.          IN      A

;; ANSWER SECTION:
chat.bigcommerce.com.   900     IN      CNAME   d1fst8v83vh1i2.cloudfront.net.
d1fst8v83vh1i2.cloudfront.net. 60 IN    A       13.33.30.39
d1fst8v83vh1i2.cloudfront.net. 60 IN    A       13.33.30.101
d1fst8v83vh1i2.cloudfront.net. 60 IN    A       13.33.30.9
d1fst8v83vh1i2.cloudfront.net. 60 IN    A       13.33.30.118

;; Query time: 228 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Fri Oct 18 08:49:13 +0530 2024
;; MSG SIZE  rcvd: 156
```

```
┌──(jeon㉿demo)-[~/Sublist3r]
└─$ whatweb chat.bigcommerce.com
http://chat.bigcommerce.com [301 Moved Permanently] CloudFront, Country[UNITED STATES][US], HTTPServer[CloudFront], IP[13.33.30.118], RedirectLocation[https://chat.bigcommerce.com/], Title[301 Moved Permanently], UncommonHeaders[x-amz-cf-pop,x-amz-cf-id], Via-Proxy[1.1 4d52d2bee89a499a2c7d426aa79a8efa.cloudfront.net (CloudFront)]
https://chat.bigcommerce.com/ [200 OK] Country[UNITED STATES][US], Email[593bdd71f0e5439ba27de06ce7924ddd@sentry.io], HTML5, HTTPServer[istio-envoy], IP[13.33.30.118], Script[application/json], Strict-Transport-Security[max-age=31536000;includeSubDomains], UncommonHeaders[access-control-allow-origin,content-security-policy-report-only,x-download-options,x-content-type-options,x-envoy-upstream-service-time,x-amz-cf-pop,x-amz-cf-id], Via-Proxy[1.1 242a08df1383db0d18e5cf8b76b259ce.cloudfront.net (CloudFront)], X-XSS-Protection[1]
```

```
---------------------------------------------------------------------------
+ Multiple IPs found: 13.33.30.101, 13.33.30.9, 13.33.30.39, 13.33.30.118, 2600:9000:229f:7200:11:1d33:3680:93a1, 2600:9000:229f:3400:11:1d33:3680:93a1, 2600:9000:229
00:229f:ee00:11:1d33:3680:93a1, 2600:9000:229f:5c00:11:1d33:3680:93a1, 2600:9000:229f:9800:11:1d33:3680:93a1, 2600:9000:229f:4800:11:1d33:3680:93a1
+ Target IP:          13.33.30.101
+ Target Hostname:    chat.bigcommerce.com
+ Target Port:        443
```

```
---------------------------------------------------------------------------
+ Server: istio-envoy
+ /: Retrieved via header: 1.1 e5793992853fceac3581bde796b6f5ba.cloudfront.net (CloudFront).
+ /: Retrieved access-control-allow-origin header: *.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: Uncommon header 'x-envoy-upstream-service-time' found, with contents: 15.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't connect: SSL negotiation failed: error:0A000410:SSL routines::ssl/tls alert h
 at /var/lib/nikto/plugins/LW2.pm line 5254.
;  at /var/lib/nikto/plugins/LW2.pm line 5254.
+ Scan terminated: 20 error(s) and 4 item(s) reported on remote host
+ End Time:           2024-10-18 08:58:52 (GMT5.5) (384 seconds)
---------------------------------------------------------------------------
```

Proposed mitigation or fix.

In order to tackle security misconfiguration vulnerabilities effectively organizations need to implement a strategy that includes prevention, detection, and resolution measures, in place. Let's explore some tactics for mitigating these risks;

Regular security audits and assessments are essential, for ensuring the safety and integrity of a system or network.

- Perform vulnerability scans to detect misconfigurations and vulnerabilities, in applications, servers, and network devices.
- Regularly conducting penetration testing is crucial to uncover vulnerabilities, within systems and expose any misconfigurations that malicious actors could exploit.

Establishing baseline configurations, for all components such, as servers, databases, and network devices is crucial to align with industry standards and compliance regulations.

- Employ automated configuration management tools such, as Chef, Puppet, Ansible, or Terraform to ensure uniformity in configurations and streamline the process of verifying compliance measures.

Enhancing Security Measures-

- Adhere to security enhancement recommendations tailored for technologies (such, as web servers, databases and cloud services) aiming to minimize features and services.

- Eliminate any features that are not, in use to reduce the potential points of entry, for cyber attacks.

Access control and permission management-

- Make sure that users and applications only have the permissions they need to carry out their tasks following the Principle of Least Privilege.
- It's important to check user roles and permissions to make sure they match their job duties.

Practices for Ensuring Secure Development:

- Ensure that you follow coding standards, by incorporating practices and guidelines to avoid introducing vulnerabilities while working on development tasks.
- Regularly review your code- Conduct security testing to spot and fix any misconfigurations before deploying it.

Ensure that logging is enabled by implementing logging for all systems and services to capture and analyze security incidents.

Utilize Security Information and Event Management (SIEM) systems to monitor logs in time for any behavior or errors.

Patch management:

- Remember to update all your software programs and devices with the security patches and updates to ensure they stay secure and functional.
- Utilize automated software to efficiently manage and deploy patches throughout the organizations infrastructure.

Security training and awareness are components of maintaining an environment.

- Ensure that developers and system administrators participate in security training sessions to educate them on the security practices and the significance of maintaining secure configurations within the organization.
- Practice security incident response drills to help teams get ready to handle security incidents.

Keep your security policies current by ensuring that you have the documentation on hand, about security procedures and configuration standards.

Consistently revise a plan, for responding to incidents that cover the steps, for recognizing and addressing misconfiguration issues.

Utilize Security Frameworks to assist the organization, in managing security configurations by following established guidelines such, as CIS Controls and the NIST Cybersecurity Framework.

By putting these measures into action organizations can greatly lower the chance of security flaws due, to misconfiguration. Improve their security stance. It is crucial to have monitoring and training along with management, in place to uphold a safe environment.